

Experiment 5: Implementing Controls & Compensating Control Attestation

Aim

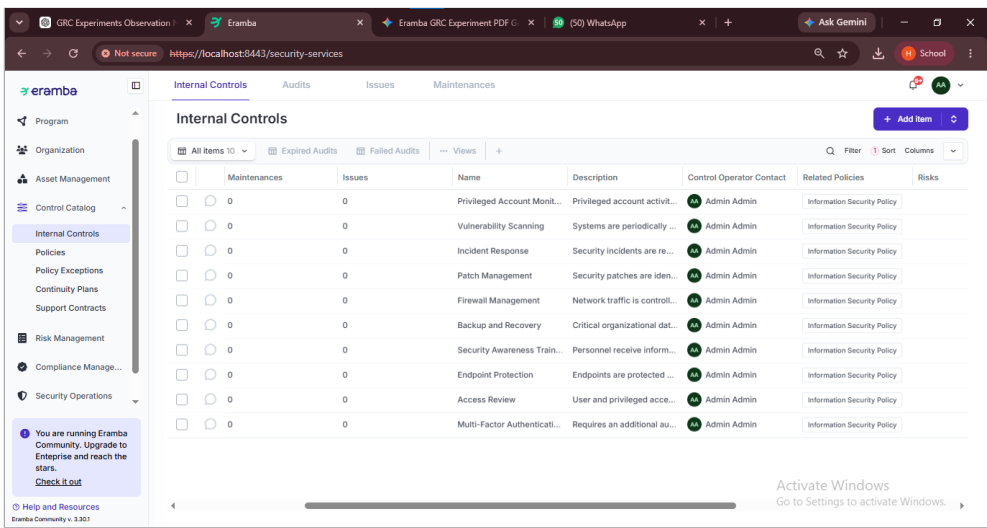
To implement security controls in Eramba and verify their audit/attestation status.

Procedure

- 1. Go to **Control Catalog** → **Internal Controls**.
- 2. Create/import internal controls.
- 3. Select a control such as **Privileged Account Monitoring**.
- 4. Open **Edit** → **Audits**.
- 5. Set the audit date and select **Audit Owner** and **Audit Evidence Owner**.
- 6. Verify the audit methodology and success criteria.
- 7. Save the control.

Output

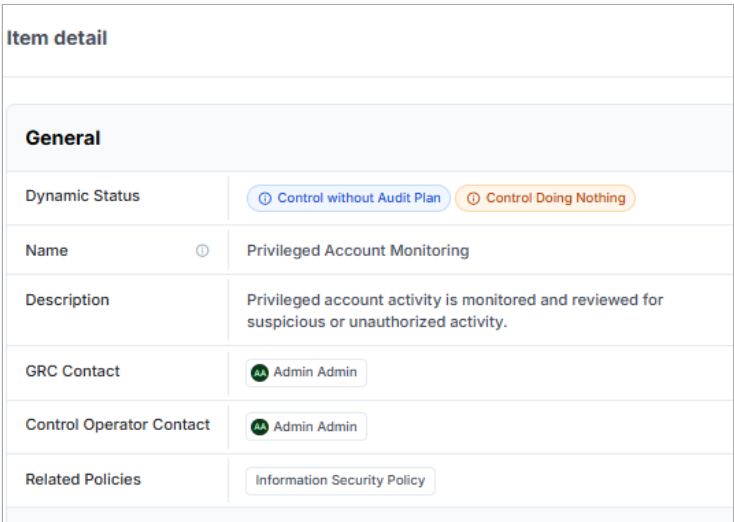
10 internal controls were created, and an audit/attestation plan was configured for **Privileged Account Monitoring**.



The screenshot shows the Eramba web interface with the 'Internal Controls' tab selected. A table lists 10 internal controls, each with a checkbox, maintenance and issue counts, name, description, control operator contact, related policies, and risks. The controls include Privileged Account Monitoring, Vulnerability Scanning, Incident Response, Patch Management, Firewall Management, Backup and Recovery, Security Awareness Training, Endpoint Protection, Access Review, and Multi-Factor Authentication.

	Maintenances	Issues	Name	Description	Control Operator Contact	Related Policies	Risks
☐	0	0	Privileged Account Monit...	Privileged account activit...	Admin Admin	Information Security Policy	
☐	0	0	Vulnerability Scanning	Systems are periodically ...	Admin Admin	Information Security Policy	
☐	0	0	Incident Response	Security incidents are re...	Admin Admin	Information Security Policy	
☐	0	0	Patch Management	Security patches are iden...	Admin Admin	Information Security Policy	
☐	0	0	Firewall Management	Network traffic is controll...	Admin Admin	Information Security Policy	
☐	0	0	Backup and Recovery	Critical organizational dat...	Admin Admin	Information Security Policy	
☐	0	0	Security Awareness Train...	Personnel receive inform...	Admin Admin	Information Security Policy	
☐	0	0	Endpoint Protection	Endpoints are protected ...	Admin Admin	Information Security Policy	
☐	0	0	Access Review	User and privileged acce...	Admin Admin	Information Security Policy	
☐	0	0	Multi-Factor Authenticati...	Requires an additional au...	Admin Admin	Information Security Policy	

Fig 5.1 – Internal Controls List (10 Items)



The screenshot shows the 'Item detail' page for the 'Privileged Account Monitoring' control. It includes a 'Dynamic Status' section with buttons for 'Control without Audit Plan' and 'Control Doing Nothing'. Below are fields for Name, Description, GRC Contact, Control Operator Contact, and Related Policies.

Item detail	
General	
Dynamic Status	Control without Audit Plan Control Doing Nothing
Name	Privileged Account Monitoring
Description	Privileged account activity is monitored and reviewed for suspicious or unauthorized activity.
GRC Contact	Admin Admin
Control Operator Contact	Admin Admin
Related Policies	Information Security Policy

Fig 5.2 – Control Item Detail General View

Audits	
Audit Dates	2027-08-27
Audit Methodology ⓘ	Review control operation and supporting evidence.
Audit Success Criteria ⓘ	Control is implemented and operating as intended.
Audit Owners	 Admin Admin
Audit Evidence Owners	 Admin Admin
Maintenances	
Maintenance Dates	
Task Description ⓘ	
Maintenance Owners	

Fig 5.3 – Control Audit & Attestation Plan Configuration

Result

Controls were successfully implemented in Eramba and the control audit/attestation process was configured.